

ClawVAPT Enterprise Report

Job: JOB-02c4828d

Web: <https://demo-owned-site.local/>

Repo: -

Commit: -

Scope: demo-owned-site.local

Severity C/H/M/L/I: 0/3/2/3/1

Tool Matrix:

zap-baseline.py INCOMPLETE not_installed
nuclei INCOMPLETE adapter_available_not_executed_in_demo
testssl.sh INCOMPLETE not_installed
semgrep INCOMPLETE adapter_available_not_executed_in_demo
gitLeaks INCOMPLETE adapter_available_not_executed_in_demo
trivy INCOMPLETE adapter_available_not_executed_in_demo
osv-scanner INCOMPLETE not_installed
checkov INCOMPLETE not_installed
syft INCOMPLETE not_installed
grype INCOMPLETE not_installed

Findings Summary:

HIGH: Runtime .env exists in workspace
HIGH: Secret-like pattern redacted
HIGH: Potential unsafe GitHub Actions trigger
MEDIUM: Missing Content-Security-Policy
MEDIUM: Dockerfile may run as root
LOW: Server header disclosure
LOW: Missing Dependabot config
LOW: Dockerfile missing HEALTHCHECK
INFO: Exposed .env check performed

Manual Review Priorities: IDOR/authZ, workflow bypass, payment integrity, tenant isolation, AI/tool misuse.

Remediation: prioritize Critical/High, secrets rotation, authZ review, dependency patching, header hardening.

Evidence redacted. Manual validation required before closure.